

Cybersécurité

Enseignant : Wael MEGUEBLI
wmeguebli@esiee-it.fr



CCI PARIS ILE-DE-FRANCE

01
—

Les enjeux de la sécurité informatique

Chapitre I : Les enjeux de la sécurité informatique

- 1 Définition de la sécurité informatique
- 2 Les objectifs de la sécurité informatique
- 3 Les risques des attaques informatiques

Définition de la sécurité informatique :

La sécurité informatique est l'ensemble des techniques qui assurent que les ressources du système d'information (matérielles ou logicielles) d'une organisation sont utilisées uniquement dans le cadre où il est prévu qu'elles le soient.

Les objectifs de la sécurité informatique :

- La confidentialité : assurer que seules les personnes autorisées aient accès aux ressources échangées.
- L'intégrité : garantir que les données sont bien celles que l'on croit être.
- La disponibilité : maintenir le bon fonctionnement du système d'information.

Les risques des attaques informatiques

Une cyber-attaque est une atteinte à des systèmes informatiques réalisée dans un but malveillant. Elle cible différents dispositifs informatiques : des ordinateurs ou des serveurs, isolés ou en réseaux, reliés ou non à Internet, des équipements périphériques tels que les imprimantes, ou encore des appareils communicants comme les téléphones mobiles, les « smartphones » ou les tablettes. Il existe quatre types de risques cyber aux conséquences diverses, affectant directement ou indirectement les particuliers, les administrations et les entreprises.



Cybercriminalité



Atteinte à l'image



Espionnage



Sabotage

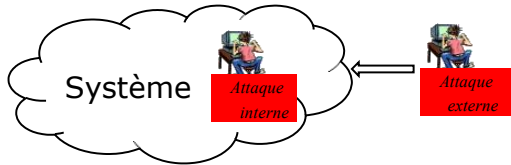
Exercice

- 1) Si vous étiez victime d'une attaque cybercriminelle, quelles pourraient être les conséquences (impacts) sur votre vie privée (deux exemples) ?
- 2) Citer les trois principaux besoins de sécurité.
- 3) Choisir ci-dessous 2 exemples de données électroniques sensibles pour une université/école :
 - *Le nom et l'origine de l'université ;
 - *Les noms des professeurs ;
 - *Les brevets déposés ;
 - *Les épreuves d'examens à venir.
- 4) Pourquoi vérifier l'intégrité d'un logiciel ?
- 5) Comment pouvez-vous protéger la confidentialité de vos données ?
- 6) Quels sont les risques des attaques informatiques ?

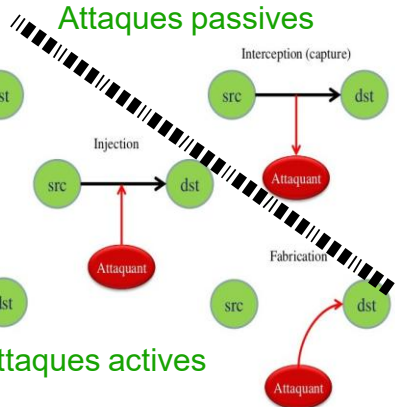
02

Typologies des attaques informatiques

Typologies des attaques



Type d'attaque	Propriétés visées
Interception	confidentialité
Interruption	disponibilité
Injection	Intégrité
Modification	Intégrité
fabrication	authenticité



Attaques passives/actives

On peut classer les attaques selon deux classes :

Attaques passives : tentent de collecter ou utiliser des informations relatives au système.

Attaques actives : tentent d'introduire des modifications sur les ressources du système ou affecter leur fonctionnement normal.

Attaques passives

Écoute et analyse du trafic réseau

Exemple d'outils: wireshark.

But: trouver des informations susceptibles d'intéresser un attaquant.

Attaques actives

Modification des données stockées ou en transit.

Injection de données.

Rejeu: ré-envoyer d'anciennes données.

Fabrication (mascarade): injecter des données en spécifiant une adresse source légitime.

Suppression de données,...

Table de comparaison

	Attaque active	Attaque passive
De base	Une attaque active tente de modifier les ressources du système ou d'affecter leur fonctionnement.	L'attaque passive tente de lire ou d'utiliser les informations du système mais n'influence pas les ressources du système.
Nuire au système	Cause toujours des dommages au système.	Ne provoque aucun mal.
Modification de l'information	Se produit	N'a pas lieu
Menace à	Intégrité et disponibilité	Confidentialité
Tâche effectuée par l'attaquant	La transmission est capturée en contrôlant physiquement la partie d'un lien.	Juste besoin d'observer la transmission.

Qu'est-ce qu'un Malware

Définition d'un Malware

Un malware « malicious software » est un terme générique qui décrit tous les programmes ou codes malveillants qui peuvent être nocifs pour les systèmes. Les malwares cherchent à envahir, endommager ou mettre hors service les ordinateurs, les systèmes informatiques, les tablettes ou les appareils mobiles.

Cycle de vie

Le cycle de vie d'un virus informatique se déroule en sept phases :

- *Phase 1 : Création*
- *Phase 2 : Gestation*
- *Phase 3 : Reproduction (l'infection)*
- *Phase 4 : Activation*
- *Phase 5 : Découverte*
- *Phase 6 : Assimilation*
- *Phase 7 : Eradication*

Classification des Malwares

Il existe une quantité phénoménale de logiciels indésirables ou malveillants. C'est ce que nous appelons plus communément des malwares. Il en existe différents types :

- ❖ **Ransomwares** (rançongiciel) : est un code malveillant qui bloque l'accès à un appareil ou à des fichiers en les chiffrant et qui réclame au victime le paiement d'une rançon pour obtenir le déchiffrement de ses données.
- ❖ **Spyware** (logiciel espion) : permet de connaître et de collecter toute l'activité de l'utilisateur sur son ordinateur les informations à son insu ou sans son consentement (mots de passe, épingles, informations de paiement ou messages...)

❖ **Bombe logique :**

Une Bombe logique est une partie d'un programme malveillant (virus, cheval de Troie, etc.) qui reste dormante dans le système hôte jusqu'à ce qu'un instant ou un événement survienne, ou encore que certaines conditions soient réunies, pour déclencher des effets dévastateurs en son sein.

Les vulnérabilités des utilisateurs

Les logiciels espions sont regroupés en 2 grandes familles : les Keyloggers et les Adwares.

Keyloggers : un enregistreur de frappe surveille l'activité des utilisateurs. Il est souvent utilisé par un patron désirant surveiller l'activité en ligne de ses employés ou par des parents pour surveiller leurs enfants. Mais lorsqu'il est utilisé à des fins malveillantes, il peut voler les mots de passe ou les codes de carte bancaire de sa victime.

Adware : n'est pas un virus très agressif. Il se contente de suivre l'activité de navigation d'un utilisateur pour déterminer les annonces à diffuser et de modifier la page de démarrage du navigateur internet ou d'installer un plug-in de recherche sur internet. Son but étant de faire venir l'utilisateur sur un site web pour lui montrer de la publicité et de voler des informations personnelles afin de les vendre à des annonceurs.

Les vulnérabilités des utilisateurs

❖ Virus

Un virus est un morceau de code, un programme qui s'insère dans une application et s'exécute lorsque celle-ci est ouverte. Il a la particularité de s'auto-reproduire en infectant d'autres programmes. Une fois à l'intérieur d'un réseau, il peut être utilisé pour voler des données sensibles, lancer des attaques DDoS ou mener des attaques de ransomware.

❖ Worm (ver)

Cible les vulnérabilités des systèmes d'exploitation pour s'installer dans les réseaux. Plus facile à programmer qu'un virus, il utilise internet sous toute ses formes pour se propager via des emails, des sites web ou des serveurs FTP. Une fois en place, le ver peut être utilisé par les cybercriminels pour lancer des attaques DDoS, voler des données sensibles ou mener des attaques de ransomware.

Les vulnérabilités des utilisateurs

- ❖ **Trojan** (cheval de Troie) : est un logiciel malveillant, souvent téléchargé par mégarde par l'utilisateur qui clique sur la pièce jointe d'un email piégé, qui a pour but de faire profiter à un tiers les ressources de votre ordinateur.
- ❖ **Les Rootkits** : Les rootkits sont des logiciels qui permettent au cybercriminel de contrôler à distance l'ordinateur d'une victime avec des privilèges administratifs complets.
- ❖ **Les Botnets** : un bot est un logiciel qui exécute des tâches automatisées sur commande. Utilisés à des fins malveillantes, ils se propagent automatiquement et peuvent se reconnecter à un serveur central. Les bots sont utilisés en très grand nombre pour créer un botnet (un réseau de bots) pour lancer des attaques de grande envergure à distance comme les attaques DDoS.

Les vulnérabilités des utilisateurs

❖ Porte dérobée

Une porte dérobée est un moyen de contourner les mécanismes de contrôle d'accès. Il s'agit d'une faille du système de sécurité due à une faute de conception accidentelle ou intentionnelle (cheval de Troie en particulier). C'est donc une fonctionnalité inconnue de l'utilisateur légitime qui donne un accès secret au logiciel. Une porte dérobée a été découverte dans le SGBD interbase de Borland au début des années 2000. Il suffisait d'entrer le nom d'utilisateur “ politically ” et le mot de passe “ correct ” pour se connecter à la base de données avec les droits d'administrateur.

Les vulnérabilités des réseaux

Une attaque par déni de service vise à rendre indisponible un ou plusieurs services. Un déni de service peut consister à exploiter, par exemple, une vulnérabilité logicielle ou matérielle. L'interruption de service peut également s'effectuer en empêchant l'accès à ce service, par exemple en saturant la bande passante du réseau : on parle alors d'attaques volumétriques. Par ailleurs, une attaque peut solliciter, jusqu'à épuisement, une ou plusieurs ressources d'un service. Il peut s'agir, par exemple, de l'ouverture d'un grand nombre de nouvelles sessions TCP dans un intervalle de temps très court, ou encore d'un nombre trop important de traitements concurrents effectués par une base de données.

On parle de DDOS « déni de service distribué » lorsque l'attaque fait intervenir un réseau de machines (souvent compromises) afin d'interrompre le ou les services visés.

Les vulnérabilités des réseaux

→ Ce type d'attaque ne permettent pas à l'attaquant d'avoir accès à l'information sur le système ni de la modifier.

→ Ce type d'attaque est dirigé contre la disponibilité de l'information/services.

Il y a deux façons de réaliser ce type d'attaques:

Mauvais trafic (bad packets) : envoyer une requête qui ne respecte pas les normes et les standards des protocoles de communication afin que la destination ne comprenne pas la requête et arrête de fonctionner.

Surcharge de trafic (DOS/DDOS) : Perturbation de l'utilisation normale des ressources (réseau ou système) en les surchargeant de trafic pour dégrader leurs performances.

Les vulnérabilités des réseaux

- Déni d'accès à l'information: rendre l'information indisponible.
- Déni d'accès aux applications: prend pour cible l'application qui traitent l'information. Si l'application n'est pas disponible l'entreprise ne peut exécuter les tâches qui sont réalisés par cette application.
- Déni d'accès aux systèmes: rendre les systèmes indisponibles. Dans ce type d'attaque, le système, et toutes ses applications ainsi que l'information deviennent indisponibles.
- Déni d'accès aux communications: dans ce type d'attaques les médias de communication qui sont pris pour cible. Par exemple, saturation du trafic réseau par le brouillage (trafic inutile). Normalement le système, les applications et l'information ne sont pas compromis, mais l'absence de communication empêche qu'ils soient accessibles.